



Navigating Chaos: A Ransomware & Exfiltration Attack

A critical incident compromised a prison's IT infrastructure and legacy systems, requiring immediate coordinated response.... *which did not occur.*

REVERSE

Security Professional Profile

Richard Suls

Technical Identity

[Querying whois.suls.net]

IP: 10.42.0.42

ham radio callsign: KB1BKF

CC: US

Registry: arin

Signal: suls.01

email: Richard@Suls.net

Richard.Suls@reversesec.com

LI: richardsuls

Professional Role

- Senior Security Advisory Consultant
- US Lead, Security Advisory
- Court-Certified Expert Witness, US Federal Courts, Various State Courts.

Areas of Expertise

- Security Advisory Services
- vCISO
- Digital Evidence Analysis and Forensics
- Tabletops/IR Exercises
- Threat Modeling

Introduction: A Preventable Disaster

Attack Overview

Phishing campaign leads to full system compromise.

Key Failures

Legacy systems, lack of response plan, destroy all evidence.

Impact

Massive data breach, operational paralysis, and reputational damage.

REVERSEC

Background: A Perfect Storm of Neglect

1 Legacy Systems

Outdated software and hardware lacked security updates.

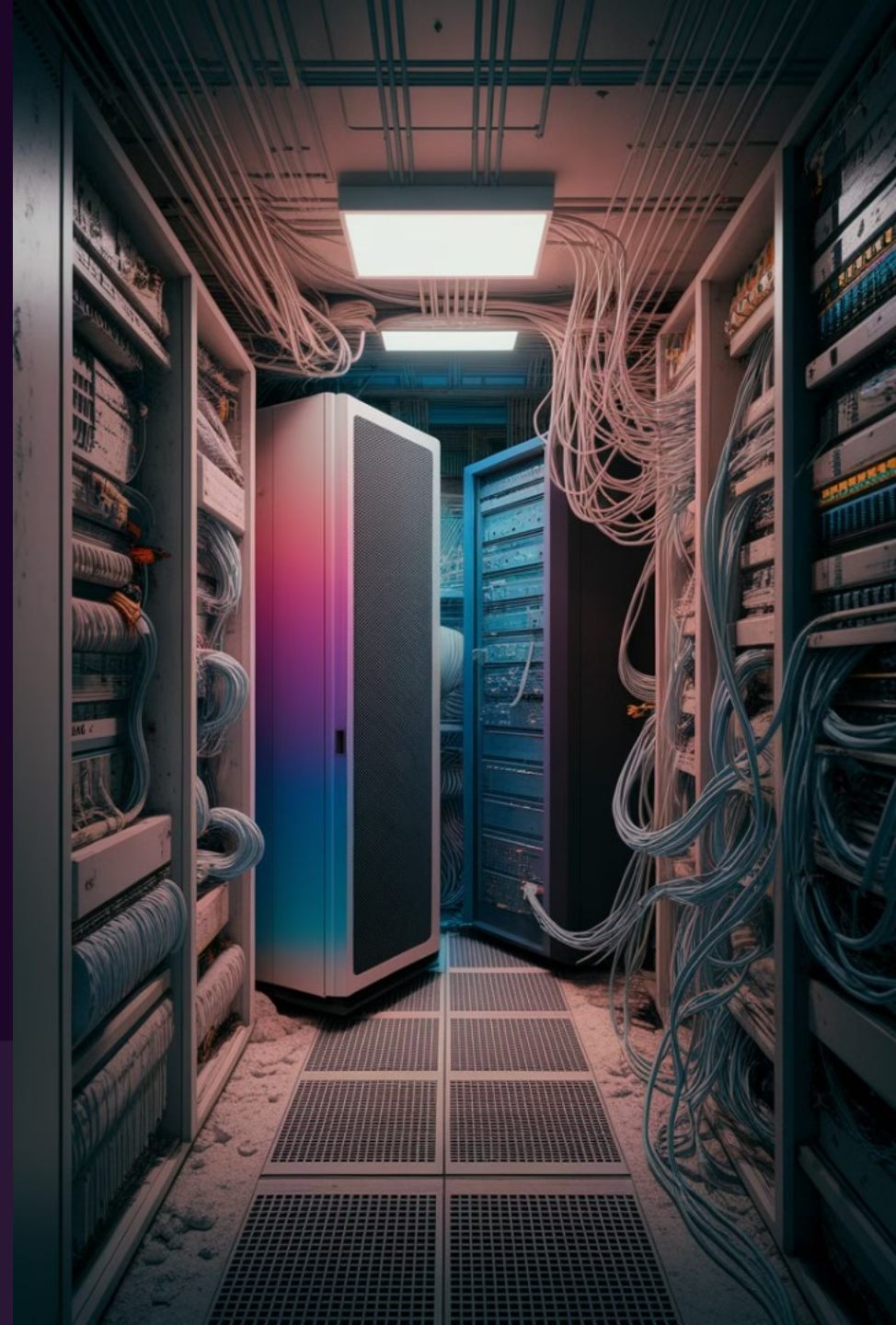
2 Poor Security Hygiene

Inadequate patching and weak password policies.

3 No IR Plan

Absence of documented incident response procedures.

REVERSESEC



Attack Timeline Overview

1

Phase 1

Phishing email targets prison staff.

2

Phase 2

Initial system compromise and access gained.

3

Phase 3

Lateral movement, primarily through SMB shares.

4

Phase 4

Data exfiltration and dark web exposure.





Phishing Email Entry Point

Targeted Attack

Email mimics legitimate communication.

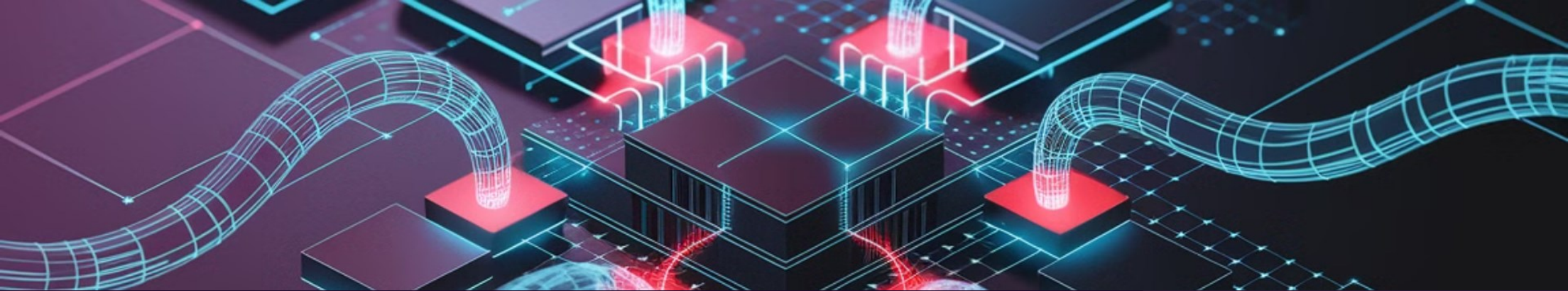
Malicious Attachment

Contains malware payload for system compromise.

User Interaction

Unsuspecting employee opens attachment, activating malware.

REVERSESEC



Initial Compromise: Exploiting Weaknesses

1

Vulnerability Exploitation

Malware exploits unpatched software vulnerabilities.

2

Credential Theft

Attackers steal user credentials for deeper access.

3

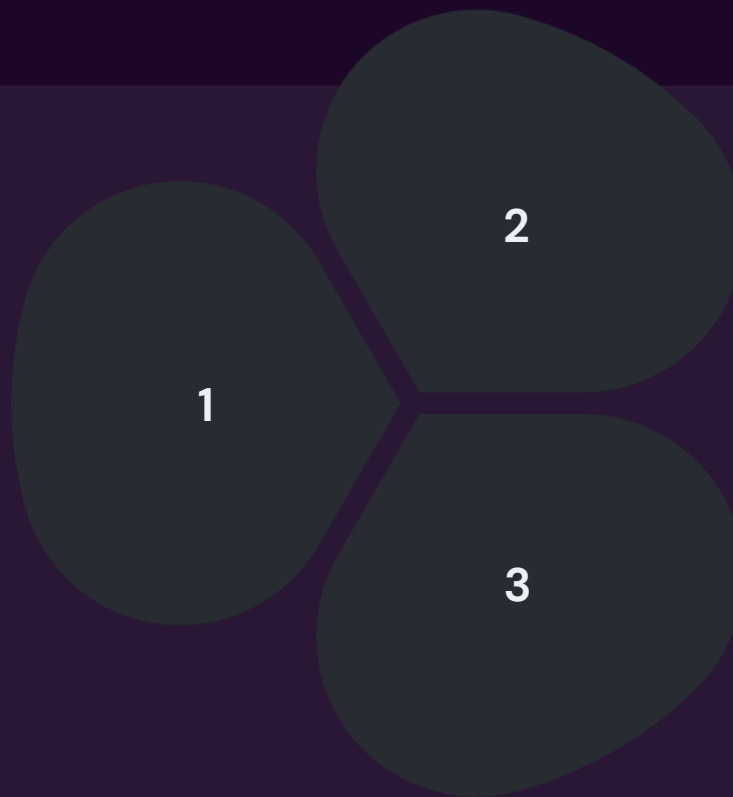
System Control

Attackers gain control over compromised systems.

Lateral Movement (& Escalation ???)

Weak Security Practices

Lack of network segmentation enabled lateral movement.



PII in Plain Sight

Documents containing PII as old as 10+ years stored on local user folders.

Unrestricted Access

Moved freely across the prison network.

Backup Encryption & System Wipe

1

Backup Destruction

Attackers encrypted all available backup files.

2

Infrastructure Wipe

PCs, workstations, and servers were wiped clean by staff in panic response.

3

Operational Paralysis

The prison's entire IT infrastructure rendered useless.

REVERSESEC

Lack of Logs & Evidence

1

Insufficient Logging

Poor logging practices left little forensic data.

2

Evidence Destruction

Staff actively deleted logs to "contain threat", too little, too late.

3

Investigation Impaired

Made incident investigation extremely difficult.

REVERSESEC

Threat Actor's First Warning



Data Exfiltration Evidence

Attackers post samples of stolen data online.



IT Staff Inaction

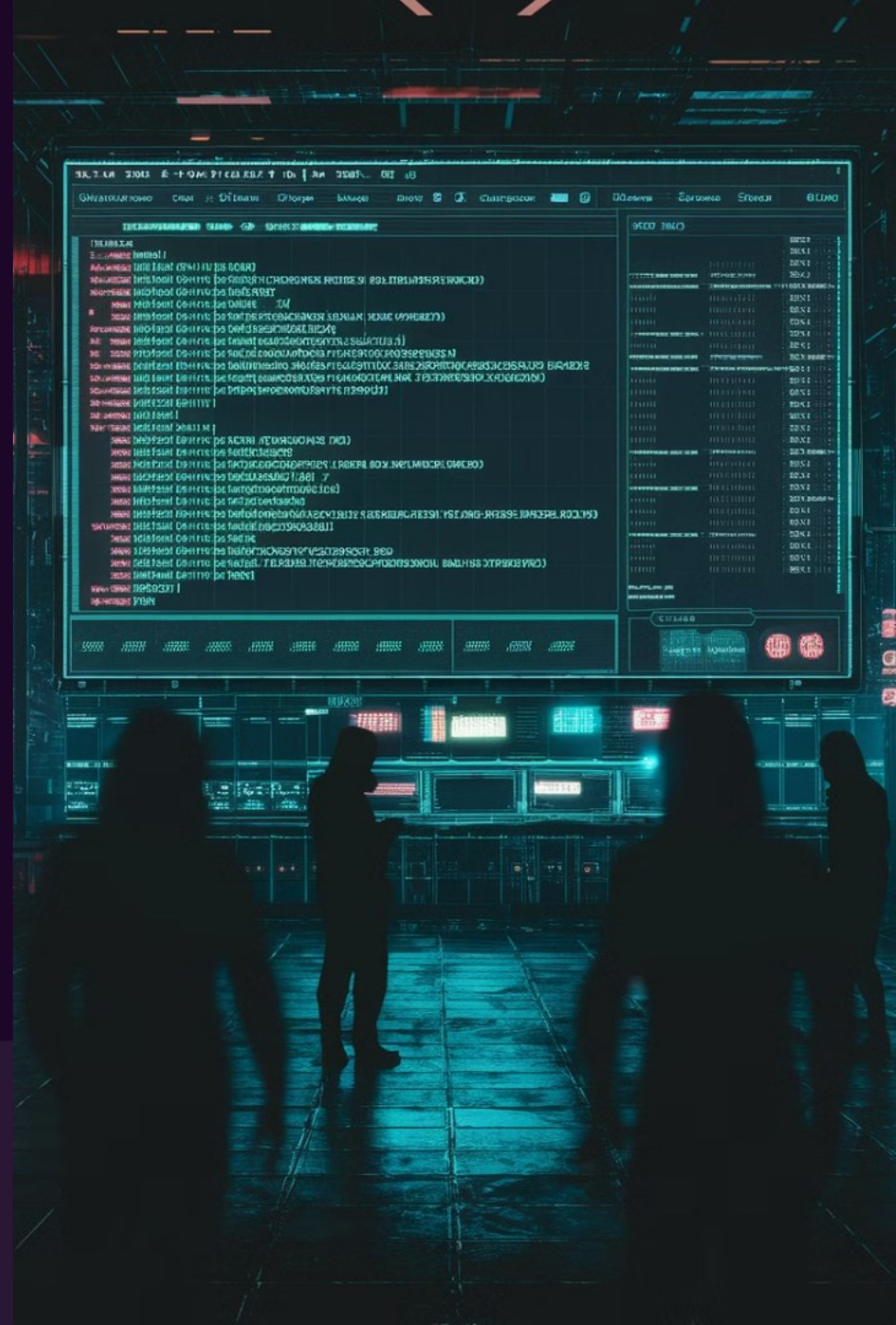
Warnings are dismissed, no investigation initiated.



Missed Opportunity

A chance to contain the breach lost.

REVERSESEC



Threat Actor's Second Warning

Direct Communication

Threat actor calls the prison's front desk.

Demands & Threats

Ransom demanded, data release threatened.

Ignored Again

Call dismissed, no action taken.

REVERSE



Data Dump to Dark Web

250GB

Data Volume

Amount of PII and NPI leaked online.

Millions

Records Exposed

Prisoner and staff data compromised.



Ongoing impact

Identity theft, fraud and potential
blackmailing of victims

REVERSESEC

Regulatory & Compliance Violations

1

CJIS

Criminal Justice
Information Services
compliance.

2

HIPAA

Health Insurance
Portability and
Accountability Act.

REVERSESEC



How This Could Have Been Prevented

1

Patching

Regular software updates to address vulnerabilities.

2

IR Plans

Documented incident response procedures.

3

Staff Training

Security awareness and phishing training.

4

Segmentation

Network segmentation to limit lateral movement.

REVERSESEC





Lessons for Other Organizations

Proactive Measures

Implement preventative security controls.

Incident Readiness

Prepare for inevitable cyberattacks.

Continuous Monitoring

Regular security audits and monitoring.

Proposed Remediation Steps

1

Incident Response

Initiate a thorough incident investigation.

2

Security Awareness

Conduct comprehensive training.

3

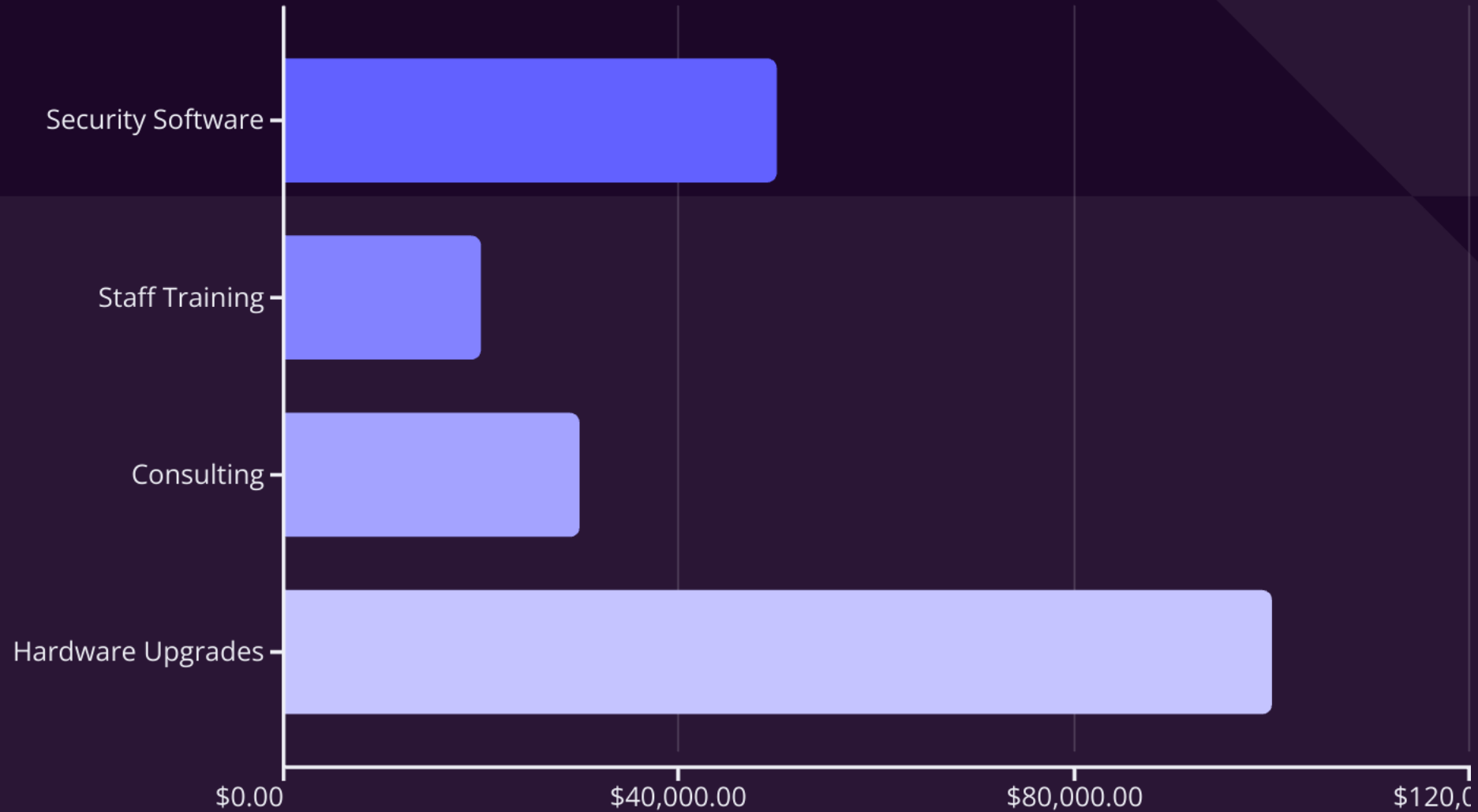
Backup Improvement

Implement secure and tested backup solutions.

REVERSESEC



Budget & Funding Requirements



Investing in cybersecurity is far more cost-effective than dealing with the aftermath of a major breach.

Opportunities



There is a Need

Many such institutions require external cybersecurity expertise, creating both humanitarian and financial opportunities for consultancies.



Do Good While Doing Well

Offer impactful solutions that balance individual safety with societal benefit, leveraging grants or tiered pricing models.



Cybersecurity & Legacy Upgrades

Provide scalable, tailored services to modernize outdated systems and mitigate security risks effectively.

REVERSESEC

Final Takeaways

1

Prioritize Security

Treat cybersecurity as a critical business function.

2

Invest Wisely

Allocate sufficient budget to security measures.

3

Stay Vigilant

Continuously monitor and improve security posture.

REVERSESEC

Thank You

Let's Stay Connected

Questions or comments? Contact me anytime.

Richard@Suls.net

Suls@Reversesec.com

Signal: suls.01

Locate me at `/dev/human`

